

Laporan Keamanan Informasi

Proposal Teknis Proyek

Kelompok 3	Pangeran Sunday Marcellino P.S.H - G6401231035 Felicia - G6401241060 Benadeo Eldian Manting - G6401231117
Mata Kuliah	KOM1315 Keamanan Informasi
Sistem	IPB Academic Service Helper (IPB ASH)

Proposal Teknis Proyek

1. Identitas Proyek

- Mata kuliah: KOM1315 Keamanan Informasi
- Nama sistem: IPB Academic Service Helper (IPB ASH)
- Bentuk sistem: Sistem Academic Service Helper
- Fokus pengembangan keamanan:
- Repositori:

2. Latar Belakang

IPB Academic Service Helper adalah rancangan sistem informasi untuk membantu mahasiswa dan civitas akademika mengajukan pertanyaan, melaporkan kendala administratif, dan mengakses panduan layanan kampus. Sistem ini juga membantu staff helpdesk (layanan pelanggan kampus) dalam mengelola tiket antrian, mendistribusikan tugas ke unit kerja terkait, dan meninjau penyelesaian masalah pengguna. Admin platform berperan mengawasi aktivitas sistem, mengelola data pengguna, dan menjaga kualitas serta validitas informasi pada pangkalan data bantuan.

Sebagai sistem yang menangani data pribadi, data akademik, keluhan internal, dan riwayat interaksi sensitif, IPB Academic Service Helper membutuhkan kontrol keamanan yang jelas. Pada tahap awal analisis ini, IPB Academic Service Helper diasumsikan belum memiliki sistem keamanan yang matang, kondisi tersebut menimbulkan risiko keamanan karena pengguna dengan peran berbeda dapat berinteraksi dengan data yang sensitif. Tanpa kontrol keamanan yang baik, sistem rentan terhadap kebocoran data kredensial melalui serangan Rainbow Table, akses ilegal atau manipulasi data sensitif seperti NIM dan isi pesan pengajuan pada basis data, pelanggaran hak akses antar-peran, serta penyangkalan (repudiation) atas pengajuan yang telah dikirim oleh pengguna.

3. Deskripsi Sistem IPB Academic Service Helper

Sistem memiliki tiga aktor utama:

Aktor	Deskripsi	Kebutuhan utama
Mahasiswa	Pengguna utama sistem yang memerlukan bantuan atau layanan administratif terkait kegiatan akademik mereka di kampus.	• Mengajukan pertanyaan atau laporan kendala administratif. • Melacak status penyelesaian tiket/aduan secara real-time. • Menandatangani pengajuan secara digital (Digital Signature) menggunakan Private Key untuk menjamin validitas dan aspek non-repudiation.
TU	Staf operasional yang bertanggung jawab merespons, memproses, dan menyelesaikan kendala atau permohonan yang diajukan oleh mahasiswa.	• Mengelola tiket antrian bantuan yang masuk. • Mendistribusikan tugas atau berkoordinasi dengan unit kerja terkait. • Memverifikasi tanda tangan digital pengajuan mahasiswa menggunakan Public Key. • Memperbarui status penyelesaian masalah dan memberikan umpan balik kepada mahasiswa.

Alur utama sistem:

1. **Login Pengguna:** Mahasiswa, Staf TU, dan Admin masuk ke sistem menggunakan akun email kampus IPB yang telah terdaftar.
2. **Mahasiswa Mengajukan Tiket/Aduan:** Mahasiswa membuat laporan kendala akademik atau mengajukan pertanyaan, lalu menandatangani formulir tersebut secara digital sebelum dikirim.
3. **Sistem Pendistribusian Tiket:** Sistem secara otomatis memasukkan pengajuan ke dalam antrian *helpdesk* berdasarkan kategori masalah yang dipilih.
4. **Staf TU Meninjau dan Memproses Aduan:** Staf TU memverifikasi validitas pengajuan mahasiswa, meninjau detail masalah, dan mendistribusikan tugas ke unit kerja terkait jika diperlukan.
5. **Staf TU Menyelesaikan Masalah:** Staf TU memperbarui status penyelesaian tiket, memberikan solusi atau umpan balik langsung kepada mahasiswa di dalam sistem.
6. **Mahasiswa Menerima Solusi:** Mahasiswa melihat pembaruan status, menerima jawaban atau dokumen yang diperlukan, dan dapat menutup tiket jika masalah sudah selesai.

4. System Overview

- Sistem belum memiliki mekanisme enkripsi, kontrol akses berbasis peran (RBAC), audit logging, maupun tanda tangan digital.
- Sistem berinteraksi langsung dengan data sensitif tanpa adanya pengamanan yang memadai.
- Sistem rentan terhadap kebocoran kredensial akibat serangan Rainbow Table.
- Data NIM dan isi pengajuan aduan mahasiswa rentan terhadap manipulasi oleh pihak tidak bertanggung jawab.
- Sistem tidak memiliki kontrol yang jelas sehingga rentan terhadap pelanggaran hak akses antar-peran.
- Sistem rentan terhadap tindakan penyangkalan (repudiation) atas pengajuan yang telah dikirim oleh pengguna.
- Belum dilakukan pengujian keamanan (security testing) khusus untuk memastikan aspek Confidentiality, Integrity, dan Accountability berjalan dengan baik

5. Aset Data

Aset	Contoh data	Tingkat sensitivitas	Risiko utama
Kredensial Autentikasi (Account Credentials)	password_hash, email	Sangat Tinggi	<i>Kebocoran password hash yang memungkinkan penyerang melakukan offline cracking (brute force hash) atau mengambil alih akun mahasiswa/staff secara ilegal..</i>
Informasi Identitas Pribadi	Nama lengkap (nama), Alamat email (email)	Tinggi	Kebocoran data identitas pengguna (data harvesting) yang dapat dieksploitasi untuk rekayasa sosial (phishing), pencurian identitas, atau penyusupan akun.
Dokumen Persyaratan Layanan	Berkas syarat yang diunggah mahasiswa yang disimpan di direktori server	Tinggi	Akses ilegal ke direktori penyimpanan file di server oleh pihak ketiga, kebocoran berkas akademis pribadi mahasiswa, atau manipulasi/penggantian file syarat dengan berkas yang merusak/tidak valid.
Dokumen Hasil Layanan Akademik	Berkas hasil resmi yang diunggah oleh staff TU (misal: surat keterangan resmi, surat rekomendasi, dsb.) yang disimpan di direktori server (file_hasil_path)	Tinggi	Kebocoran dokumen resmi yang bersifat rahasia, pemalsuan dokumen hasil (surat keterangan palsu), atau pengunduhan berkas hasil oleh pengguna yang tidak berhak (bukan mahasiswa yang mengajukan).
Data Transaksional Tiket Layanan	Deskripsi keperluan pengajuan (purpose), status tiket (status), catatan staff TU (catatan_tu)	Sedang	Modifikasi data tiket secara tidak sah (misal: mengubah isi purpose tiket orang lain, mengubah paksa status menjadi selesai tanpa melampirkan berkas hasil yang sah), dan kebocoran riwayat permohonan layanan akademik mahasiswa.

Kunci Rahasia & Konfigurasi Sistem	SECRET_KEY (JWT sign key), DATABASE_URL (kredensial database)	Sangat Tinggi	Kebocoran kunci JWT memungkinkan penyerang memalsukan identitas token siapa saja untuk mengambil alih hak akses Administrator/Staff, sedangkan kebocoran URL database dapat mengakibatkan pencurian atau penghapusan seluruh data di server database.
Log Aktivitas Sistem (Log & Audit Data)	Catatan kegagalan akses (security_logger), catatan riwayat claim tiket (audit_logger), detail error unhandled exception (_error_logger)	Sedang	Log yang bocor memberikan penyerang informasi berharga mengenai struktur internal kode, alur sistem, alamat email staff/mahasiswa, serta celah/bug pada backend yang terungkap melalui stack trace log error.

6. Vulnerability Assessment Awal

Area	Potensi celah	Dampak
Integritas Data Tiket	Tidak ada mekanisme kriptografi untuk memvalidasi keaslian data tiket, sehingga pengguna dengan akses database dapat mengubah isi tiket tanpa terdeteksi..	Data tiket akademik dapat dimanipulasi secara diam-diam tanpa memicu peringatan atau disadari oleh sistem.
Authenticity data tiket	Endpoint <code>get_ticket_detail</code> langsung mengembalikan data dari database tanpa memverifikasi apakah data telah dimodifikasi sejak pertama kali dibuat.	Mahasiswa atau staf dapat melihat dan memproses data palsu yang telah dimanipulasi tanpa adanya deteksi atau penolakan otomatis dari sistem.
Non-Repudiation Pengajuan Tiket	Tidak ada bukti kriptografis yang mengikat isi tiket dengan identitas pengaju dan stempel waktu secara tidak terbantahkan.	Risiko terjadinya penyangkalan sepihak saat terjadi sengketa pengajuan, karena sistem tidak memiliki bukti sah untuk menentukan keaslian pembuat tiket.
Non-Repudiation	Tidak adanya penandatanganan digital berbasis <i>Asymmetric Cryptography</i> (RSA) oleh pengirim.	Mahasiswa dapat menyangkal bahwa mereka telah mengirimkan suatu pengajuan atau laporan tertentu.
Implicit Trust	Sistem menerapkan kepercayaan penuh (implicit trust) bahwa semua data di database pasti valid, tanpa adanya validasi sekunder di lapisan aplikasi (defense-in-depth).	Jika database ditembus (via SQL Injection, kebocoran port, atau insider threat), aplikasi akan langsung menyajikan data yang telah dimanipulasi kepada pengguna akhir tanpa adanya pemblokiran.

7. Analisis Kebutuhan Keamanan

7.1 Matriks Keamanan CIA

- **Confidentiality**

Sistem harus memastikan bahwa data sensitif hanya dapat diakses oleh pihak yang memiliki hak akses sah dan melindungi informasi dari kebocoran.

Kebutuhan keamanan:

- Melindungi data sensitif seperti password dan token dari akses pihak yang tidak berhak.
- Menjaga kerahasiaan dokumen akademik mahasiswa agar tidak diakses secara ilegal.
- Melindungi kredensial sistem dan catatan internal Tata Usaha (TU) dari paparan luar.
- Mencegah kebocoran data pribadi (PII) civitas akademika.

- **Integrity**

Sistem harus menjamin bahwa data tidak diubah, dimanipulasi, atau dirusak oleh pihak yang tidak berhak, baik dalam penyimpanan maupun saat transmisi.

Kebutuhan keamanan:

- Menjamin keutuhan data tiket aduan dan seluruh transisi statusnya di dalam sistem.
- Memastikan berkas persyaratan yang diunggah (file upload) terlindungi dari modifikasi tidak sah.
- Menjaga keabsahan dan keakuratan data timestamp pada setiap transaksi.
- Menjamin konsistensi data dan menghindari konflik data saat terjadi akses bersamaan (concurrency).

- **Authenticity**

Sistem harus memastikan bahwa seluruh layanan, fitur, dan data selalu dapat diakses oleh pengguna yang berhak kapan-pun diperlukan tanpa adanya interupsi.

Kebutuhan keamanan:

- Memastikan gerbang sistem login selalu tersedia dan dapat diakses dengan lancar.
- Menjamin ketersediaan fitur pengajuan tiket layanan dan fungsi antrean sistem.
- Memastikan fitur untuk mengunduh (download) dokumen hasil akademik selalu siap digunakan.
- Menjamin layanan notifikasi berjalan secara konstan dan selalu aktif mengirimkan informasi.

7.2 Pilar AAA

- **Authentication**

Sistem harus memastikan bahwa pengguna yang masuk ke dalam platform benar-benar memiliki identitas resmi dan sah melalui mekanisme validasi yang ketat.

Kebutuhan keamanan:

- Memverifikasi identitas pengguna secara valid melalui kombinasi email IPB dan password.
- Menggunakan JWT token sebagai kredensial sesi digital yang sah setelah pengguna berhasil masuk.
- Menyediakan fitur brute-force protection untuk mengamankan akun dari percobaan login ilegal.
- Mengontrol keamanan sesi secara menyeluruh melalui mekanisme session management.

- **Authorization**

Sistem harus membatasi dan mengontrol hak istimewa pengguna agar hanya dapat melakukan tindakan atau mengakses data yang sesuai dengan kewenangannya.

Kebutuhan keamanan:

- Mengontrol hak akses fitur berdasarkan role atau peran spesifik aktor di dalam sistem.
- Membatasi visibilitas dan pengelolaan aduan hanya berdasarkan faktor kepemilikan tiket.
- Membatasi ruang lingkup operasional sistem disesuaikan dengan level layanan yang berlaku.
- Menerapkan matriks hak akses yang mendetail, kaku, dan spesifik untuk setiap aksi yang dilakukan pengguna.

- **Availability**

Sistem harus mampu melacak, mencatat, dan membuktikan setiap aktivitas yang terjadi di dalam platform untuk menjamin tanggung jawab penuh dari setiap aktor.

Kebutuhan keamanan:

- Melacak seluruh rekam jejak aksi melalui mekanisme dual-channel logging yang memisahkan antara security log dan audit log.
- Mengirimkan notifikasi email otomatis sebagai bukti otentik terjadinya suatu aktivitas transaksi.
- Menyimpan rekaman timestamp yang presisi di setiap log perubahan data.
- Mencatat identitas pelaku aksi secara jelas untuk mencegah tindakan penyangkalan (non-repudiation) di kemudian hari.

8. Ruang Lingkup Implementasi Keamanan

Ruang lingkup pengembangan pada tugas ini:

1. Merancang dan mengimplementasikan AAA security pada IPB Academic Service Helper.
2. Membatasi akses sistem eksklusif untuk domain email resmi IPB.
3. Menambahkan password hashing Bcrypt dan salting otomatis.
4. Menerapkan enkripsi jalur komunikasi client-server menggunakan protokol HTTPS/TLS.
5. Mengamankan otorisasi sesi API menggunakan JSON Web Token.
6. Menambahkan kontrol akses berbasis peran dan isolasi data mahasiswa.
7. Mengimplementasikan enkripsi AES-256 untuk data sensitif di database.
8. Menambahkan fungsi hashing SHA-256 untuk menjaga integritas berkas.
9. Menambahkan digital signature RSA untuk menjamin aspek non-repudiation.
10. Menambahkan audit logging permanen dan security activity log.
11. Mengisolasi seluruh kunci konfigurasi rahasia ke environment variables.
12. Menyusun log pengujian fungsional, integrasi, dan keamanan sistem.

9. Existing System Analysis

Sistem IPB Academic Service Helper pada dirancang untuk menyelesaikan masalah antrian dan pengelolaan layanan akademik mahasiswa IPB yang sebelumnya dilakukan secara manual. Sistem ini mempertemukan tiga aktor utama yaitu mahasiswa, staf TU tingkat departemen/fakultas/IPB, dan sistem notifikasi dalam satu platform berbasis web. Dari sisi fungsional, sistem membantu proses pengajuan tiket layanan, pengunggahan berkas persyaratan, antrian pemrosesan berbasis peran staf, serta pengiriman berkas hasil layanan akademik kepada mahasiswa.

Namun, sistem yang menangani dokumen akademik resmi dan data pribadi mahasiswa tidak cukup hanya memenuhi kebutuhan fungsional. Data seperti keperluan pengajuan layanan, berkas syarat yang diunggah, catatan staff TU, hingga dokumen hasil seperti surat keterangan resmi memiliki nilai sensitif yang tinggi. Jika tidak diamankan dengan baik, sistem dapat menjadi target manipulasi data tiket, pemalsuan dokumen hasil, akses tidak sah oleh pihak internal, maupun pengubahan riwayat pengajuan layanan mahasiswa tanpa jejak yang terdeteksi.

Kelemahan utama sistem yang ada adalah belum adanya mekanisme untuk menjamin keaslian dan keutuhan data tiket setelah data tersebut tersimpan di database. Sistem hanya memverifikasi identitas pengguna yang mengakses, tetapi tidak pernah memverifikasi apakah isi tiket yang dikembalikan dari database masih identik dengan data yang pertama kali diajukan mahasiswa. Tidak ada bukti kriptografis yang mengikat isi tiket pada identitas pengaju, sehingga sistem rentan terhadap ancaman insider threat maupun manipulasi database langsung yang tidak akan terdeteksi.

Oleh karena itu, pada proyek ini diusulkan integrasi Digital Signature sebagai lapisan keamanan integritas data tiket pada sistem IASH. Integrasi ini mencakup penandatanganan kriptografis setiap tiket saat dibuat menggunakan private key, penyimpanan nilai signature di database, serta proses verifikasi menggunakan public key setiap kali data tiket diakses, untuk memastikan bahwa data yang tersimpan tidak pernah dimodifikasi secara tidak sah di luar alur aplikasi.

10. Kesimpulan

Proposal teknis ini menetapkan sistem IPB Academic Service Helper sebagai sistem yang akan diamankan pada tugas PBL Keamanan Informasi. Fokus utama proyek adalah meningkatkan aspek keamanan dari sistem dengan berbagai mekanisme keamanan yang mencakup autentikasi kuat, kontrol akses berbasis peran (RBAC), enkripsi data, tanda tangan digital, serta pencatatan log audit guna melindungi integritas data akademik dan mencegah penyangkalan.

